Operationalizing CVSS v4.0 Environmental Metrics with Evidence Normalization, Governance, and Traceability

Anonymous Author(s)
Affiliation withheld for double-blind review

***Abstract*—CVSS v4.0 Environmental metrics adapt vulnerability assessment to organizational deployment context, but operationalization remains evidence-intensive and difficult to audit. We present a deterministic, machine-checkable workflow that normalizes environmental evidence, resolves candidate metrics under explicit policy, enforces human authorization checkpoints, and exports structured traces. The scoring core achieves 100% conformance across 486,472 FIRST reference vectors with zero violations over 10,000 metamorphic executions. In differential validation against an independent secondary implementation (`cvss4py`) across 486,472 vectors, the pipeline demonstrated 454,047/461,444 exact numeric score concordance (98.3970%) with zero validity disagreements, where all 7,397 observed discrepancies match official FIRST reference scores, alongside 25,028/25,028 (100.0%) syntax rejection concordance on malformed inputs under verified deterministic parity. To evaluate contract robustness, closed-world Schema v2 validation and a downstream governance override contract were established without modifying nominal policy formulas. Replaying the historical mutation complement under closed-world Schema v2 achieved 120/120 rejections (100.0%), including 16/16 subobject injections previously accepted under open-world Schema v1. In a pre-registered transfer evaluation on an external quarantined held-out corpus of $N = 938$ real-world advisories, the workflow classified 339 cases as nominal-calculable (36.1407%) and executed 599 fail-closed rejections (63.8593%) due to missing mandatory operational evidence, with zero data invention, zero autonomous overrides, and 938/938 traces validated across 3,232 machine-checkable diagnostic checks under deterministic parity. The workflow provides machine-checkable provenance and governance constraints under controlled conditions; independent human expert adjudication has not been completed (`human_adjudication_completed = false`), and confirmatory datasets C1/C2 remain sealed.**

***Index Terms*—CVSS v4.0, Environmental metrics, vulnerability prioritization, evidence normalization, governance, human-in-the-loop, traceability, reproducibility, uncertainty**

I. Introduction

Vulnerability management teams routinely face more findings than they can remediate immediately. A severity score is therefore an important input, but it does not by itself encode every factor that affects an organization's remediation decision. The same vulnerability may affect an isolated development workstation, a public identity service, a safety-relevant operational technology component, or a redundant internal service. These deployments can require different treatment even when the vulnerability's intrinsic technical characteristics are unchanged.

CVSS v4.0 explicitly separates Base, Threat, Environmental, and Supplemental metric groups [1], [2]. Base metrics communicate characteristics intrinsic to the vulnerability, whereas Environmental metrics allow a consumer organization to represent local security requirements and modified conditions [3], [4]. This separation creates an opportunity for context-aware assessment, but also an operational burden: analysts must locate evidence, interpret incomplete information, document assumptions, and preserve the reasoning behind each metric choice.

This paper investigates whether an evidence normalization and governance workflow can assist that process without modifying CVSS or displacing human judgment. We use "watcher" only to denote the deterministic evidence-ingestion and normalization component of the architecture; it is not an autonomous scoring authority. "Workflow" denotes the complete end-to-end process, including evidence processing, policy resolution, trace generation and verification, and the mandatory authorization checkpoint. The pipeline ingests candidate evidence, normalizes it into a structured scenario record, resolves reviewable candidate metric values under deterministic policy rules, identifies uncertainty, and exports trace artifacts. A human analyst remains responsible for accepting, changing, or rejecting each recommendation.

The work makes eight contributions:

1) a strict scientific separation between specification-level arithmetic conformance (486,472 FIRST reference cases; 10,000 metamorphic executions with zero violations) and controlled workflow evaluation across curated scenarios;
2) an evidence normalization and human-in-the-loop governance workflow for operationalizing CVSS v4.0 Environmental assessment;
3) a trace model linking evidence, candidate metrics, uncertainty, and review state;
4) a controlled evaluation dataset of curated scenarios exercising schema coverage (12 real NVD records, 18 synthetic cases, 22 priority shifts);
5) a closed-world Schema v2 contract that replaces open-world permissiveness, eliminating subobject injection gaps (16/16 rejections in replay) and establishing strict field and enum boundaries;
6) an auditable downstream governance override contract enforcing eight strict operational invariants, preserving nominal Equation 8 formula invariance and guaranteeing zero autonomous overrides;
7) an independent differential validation protocol evaluating

486,472 vectors against secondary comparator `cvss4py`, establishing 454,047/461,444 exact numeric concordance (98.3970%) on calculable vectors and 25,028/25,028 syntax rejection concordance (100.0%); and

8) an external held-out transfer campaign across $N = 938$ real-world advisories quarantined prior to execution, demonstrating 339 nominal-calculable assessments, 599 fail-closed abstentions under missing evidence, zero data invention, and 938/938 verified traces across 3,232 diagnostic checks.

The evaluation is deliberately descriptive. It measures artifact completeness, traceability, and context-sensitive operational transitions. It does not claim that the watcher predicts exploitation, produces an authoritative risk score, or improves remediation outcomes in production.

II. Background and Related Work

A. Severity and Environmental Context

CVSS is an open framework for communicating vulnerability characteristics and severity. CVSS v4.0 retains a Base metric group while distinguishing Threat, Environmental, and Supplemental information [2], [3]. Environmental assessment includes Security Requirements and Modified Base metrics, allowing the consumer to represent conditions that differ from the vulnerable system's default assumptions.

The need for contextualization predates CVSS v4.0. Fruhwirth and Mannisto examined the use of context information to improve CVSS-based prioritization and response [5]. Later context-aware approaches, including CAVP, combined vulnerability attributes with additional operational signals to support prioritization [6]. These approaches motivate automation, but they also show that context must be represented explicitly rather than inferred solely from a Base score.

Howland argues that CVSS has often been used outside its intended role, particularly when technical severity is treated as a complete vulnerability management decision [7]. The present work addresses that concern by retaining Base severity as a separate field and labeling the prototype's priority output as an operational category rather than an official CVSS score.

B. CVSS v4.0 Nomenclature and Scoring Mechanics

The official FIRST specification establishes four formal nomenclature tiers depending on the metric groups populated in a score vector:

- **CVSS-B:** Base metrics only, quantifying intrinsic vulnerability characteristics across Exploitability (AV, AC, AT, PR, UI), Vulnerable System Impact (VC, VI, VA), and Subsequent System Impact (SC, SI, SA).
- **CVSS-BT:** Base and Threat metrics, incorporating Exploit Maturity ($E \in \{\text{Attacked}, \text{Proof-of-Concept}, \text{Unreported}, \text{Not Defined}\}$).
- **CVSS-BE:** Base and Environmental metrics, incorporating consumer-specific context without threat intelligence.
- **CVSS-BTE:** Base, Threat, and Environmental metrics combined, reflecting contemporary exploit activity alongside consumer deployment context.

Environmental assessment in CVSS v4.0 operates across two distinct mechanisms:

1) **Modified Base Metrics:** Allow the consumer organization to override intrinsic Base values when local defenses, privilege architectures, or compensating controls alter attack difficulty or impact. These comprise Modified Attack Vector (MAV), Modified Attack Complexity (MAC), Modified Attack Requirements (MAT), Modified Privileges Required (MPR), Modified User Interaction (MUI), Modified Vulnerable System Impacts (MVC, MVI, MVA), and Modified Subsequent System Impacts (MSC, MSI, MSA). When unmodified, each metric defaults to its underlying Base value ($MX = X$).
2) **Security Requirements:** Express consumer-side mission criticality for Confidentiality Requirement (CR), Integrity Requirement (IR), and Availability Requirement (AR), taking values in $\{\text{High}, \text{Medium}, \text{Low}, \text{Not Defined}\}$. CR, IR, and AR rescale effective impact weights during MacroVector evaluation.

Under the FIRST CVSS v4.0 standard, scoring does not follow an informal arithmetic formula. Vectors are mapped into a 6-dimensional discrete MacroVector:

$$\vec{M} = (EQ_1, EQ_2, EQ_3, EQ_4, EQ_5, EQ_6) \tag{1}$$

where EQ_1 captures Exploitability (AV/PR/UI), EQ_2 captures Complexity (AC/AT), EQ_3 captures Vulnerable System Impact scaled by CR/IR/AR, EQ_4 captures Subsequent System Impact, EQ_5 captures Threat (E), and EQ_6 captures Modified Subsequent System Impact. Each MacroVector corresponds to a precomputed Equivalence Set with assigned boundary scores. The final score is resolved through deterministic interpolation between adjacent equivalence boundaries.

Crucially, the workflow presented in this paper does not reimplement or approximate this algorithm. Instead, the workflow ingests local evidence, resolves applicable policy rules into valid Modified metrics and Security Requirements, and delegates calculation to the canonical FIRST-compatible scoring core (independently validated against 486,472 official reference vectors).

C. Stakeholder-Specific Prioritization

The Stakeholder-Specific Vulnerability Categorization framework models prioritization as a decision process that depends on the stakeholder and its objectives [8]. SSVC uses decision trees and explicitly rejects a single universal ordering for every vulnerability management community. This perspective is compatible with CVSS Environmental assessment: both require consumer-specific information that cannot be obtained from the vulnerability record alone.

The workflow proposed here does not implement an SSVC decision tree. Instead, it adopts two related principles. First, the evidence record must identify the consumer context. Second, the decision artifact must remain inspectable so that an analyst can understand which local facts changed the recommendation.

D. Threat and Exploit Prediction

EPSS addresses a different question from CVSS severity. It estimates the probability that exploitation activity will be observed for a vulnerability within a future time window. Research underlying EPSS demonstrates the value of data-driven exploit prediction for allocating remediation effort [9], [10], [11].

Threat probability and Environmental impact are complementary rather than interchangeable. An exploit prediction model can inform the urgency associated with attacker activity, while Environmental metrics express consumer-side requirements and modified deployment conditions. The proposed watcher keeps those concepts separate and treats time-sensitive threat evidence as an input requiring freshness checks.

E. Enterprise Patch and Risk Decisions

NIST SP 800-40 Rev. 4 frames enterprise patch management as a lifecycle that includes identification, prioritization, acquisition, installation, and verification [12]. The guidance also emphasizes coordination between mission owners and technology management. This reinforces the need for artifacts that communicate why a vulnerability was prioritized, not merely the numeric value attached to it.

Recent empirical comparison of CVSS, SSVC, EPSS, and other scoring systems shows that different systems can rank the same vulnerabilities differently because they have different purposes and underlying signals [13]. The implication for this work is not that one system must replace the others. Instead, a defensible workflow should expose the signal being used, the decision boundary, and the evidence supporting the result.

F. Research Gap

Prior work establishes the value of contextual information, stakeholder decisions, exploit prediction, and enterprise prioritization. A remaining operational gap is the reproducible transformation of distributed local evidence into candidate CVSS v4.0 Environmental values. The contribution of this work is therefore the traceable workflow around Environmental assessment: evidence acquisition, normalization, recommendation, uncertainty signaling, human review, and reproducible export.

III. Research Questions and Design Goals

The evaluation addresses three research questions.

- RQ1: Can the workflow produce complete evidence and trace artifacts for each evaluated scenario?
- RQ2: Does consumer-side context produce observable changes in an operational priority view relative to a Base-only view?
- RQ3: To what extent does the trace schema deterministically encode evidence provenance, explicit uncertainty, policy transitions, and mandatory authorization states in a machine-checkable format?
- RQ-R6-1: Does the machine-checkable verification contract maintain integrity and coverage when transferred to an external, quarantined held-out corpus of real-world advisories?
- RQ-R6-2: How does a closed-world schema specification alter mutation detection and backward compatibility relative to the open-world baseline?
- RQ-R6-3: Can a structured downstream governance override layer make operational deviations fully auditable while preserving the mathematical invariance of the nominal policy formula?
- RQ-R6-4: What degree of numerical and validity concordance is observed between the primary scoring engine and an independent secondary implementation across an exhaustive vector corpus?

Table I maps each research question to its descriptive measure and interpretation boundary.

The design goals derived from these questions are separation of concerns, provenance, conservative uncertainty handling, deterministic exports, idempotent validation, and explicit human authority.

IV. Evidence Normalization Architecture

Figure 1 summarizes the architecture. The workflow is organized into six logical layers.

A. Source Adapters

Source adapters ingest vulnerability records and consumer-side evidence. Vulnerability identifiers, Base vectors, Base scores, severity labels, source URLs, and retrieval metadata remain distinct from local asset observations. This separation prevents curated deployment context from being represented as if it originated in NVD.

Consumer-side inputs may include asset role, exposure, privileges, security controls, redundancy, confidentiality needs, integrity needs, availability needs, and operational constraints. The prototype stores concise evidence summaries rather than claiming direct integration with a production CMDB, scanner, ticketing platform, or threat-intelligence system.

B. Evidence Normalization

The normalization layer converts heterogeneous observations into a stable scenario schema. Each record contains identifiers, official Base information, environmental context, candidate modified metrics, evidence summaries, uncertainty flags, review state, and trace references. Required-field validators detect omissions before article tables or reports are generated.

Normalization is important because an automated recommendation without a stable evidence model is difficult to review or reproduce. The architecture must therefore produce structured fields in addition to narrative text.

C. Candidate Recommendation Layer

The recommendation layer maps the normalized context to candidate Environmental values. The candidate status is essential: the output is not declared to be an authoritative score. The rationale field explains which evidence supports each recommendation, while uncertainty fields identify assumptions, stale observations, missing data, or conflicts.

TABLE I
RESEARCH QUESTIONS, MEASURES, AND INTERPRETATION BOUNDARIES

RQ	Question focus	Measures	Boundary
RQ1	Artifact completeness and reproducibility	Evidence coverage; trace completeness; validator status	Completeness does not prove metric correctness.
RQ2	Sensitivity to curated consumer context	Priority transition count; transition distribution; category delta	The category delta is not an official CVSS score delta.
RQ3	Machine-checkable provenance and authorization	Uncertainty fields; review-required state; claim-boundary checks	Trace schema completeness does not constitute independent expert adjudication.
RQ-R6-1	Held-out corpus transfer integrity	Nominal-calculable count; fail-closed abstention; diagnostic checks	Abstention on missing evidence is a safety property, not a pipeline failure.
RQ-R6-2	Closed-world schema robustness	Mutation detection rate; compatibility taxonomy; attribute injection	Closed-world strictness rejects uncanonicalized legacy records.
RQ-R6-3	Auditable governance override layer	Invariant adherence (INV-G1–G8); nominal Eq. 8 invariance	Operational overrides require human authorization; zero autonomous override.
RQ-R6-4	Independent differential validation	Exact numeric match rate; syntax rejection concordance	Concordance reflects implementation alignment; cvss4py is not an absolute reference authority.

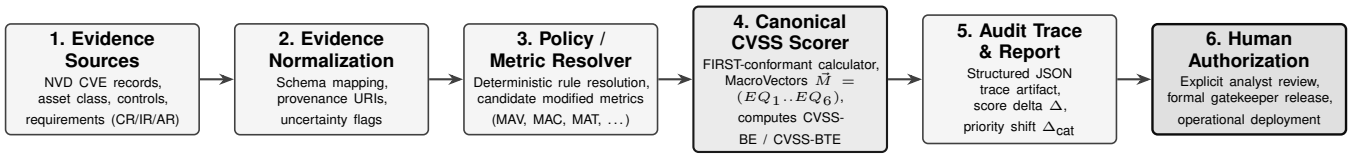


Fig. 1. End-to-end architecture of the CVSS v4.0 environmental assessment workflow, emphasizing evidence normalization, deterministic policy resolution, canonical scoring conformance, audit traceability, and explicit human authorization.

The evaluated prototype focuses on deterministic evidence normalization, governance gates, and trace generation rather than the semantic accuracy of an unconstrained generative AI model. Any assistive language processing or watcher heuristics are strictly scoped to evidence ingestion support and remain outside the scope of semantic truth validation; candidate values are resolved through structured scenario logic, deterministic policy rules, and curated evidence schemas. No claim is made that an artificial intelligence model independently discovered or empirically validated ground-truth metric values.

D. Closed-World Schema v2 Contract

The original JSON schema formulation operated under open-world semantics, permitting undeclared attributes. As revealed by exploratory mutation testing, open-world tolerance allows arbitrary undeclared payload injections ($F3$). To enforce rigorous auditability, we formulated Schema v2 as a closed-world contract. Under Schema v2, all object schemas declare `"additionalProperties": false`, requiring all ingested properties to belong to the declared normative specification. Schema v2 strictly enforces string enums (such as non-empty CVE identifiers matching $^{C}VE-$
$d4-$
$d4,$), structured object arrays for compensating controls, explicit nullability constraints, and reserved future-version field guards.

E. Downstream Governance Override Architecture

In operational environments, security analysts occasionally require policy-driven deviations from nominal algorithmic recommendations. To support these operational requirements without corrupting mathematical rigor, we introduced a downstream Governance Override layer. The override operates strictly post-scoring, leaving the nominal scoring function and prioritization formula (Equation 8) mathematically invariant.

The Governance Override layer enforces eight mandatory architectural invariants:

1) **INV-G1 (Authorization Prerequisite):** Overrides require authenticated human identity, role authorization, and non-empty rationale.
2) **INV-G2 (Nominal Preservation):** Nominal score and calculated priority are immutably preserved in the audit trace alongside the override.
3) **INV-G3 (Mandatory Justification):** Every deviation must reference verifiable evidence identifiers.
4) **INV-G4 (Separation of Roles):** Automated normalization agents are strictly prohibited from approving overrides.
5) **INV-G5 (No Autonomous Override):** Automated components cannot initiate or self-approve operational adjustments; autonomous overrides are identically zero.
6) **INV-G6 (Formula Invariance):** Equation 8 parameters, weights, and scoring rules remain byte-level immutable.
7) **INV-G7 (Audit Reproducibility):** Given the same input trace and override payload, replay reproduces identical audit states.
8) **INV-G8 (Fail-Closed Default):** Any override lacking valid authorization or complete evidence fails closed to

the nominal recommendation.

F. Differential Testing and Held-Out Protocol

To verify the scoring core beyond self-consistency, we established an independent differential testing protocol comparing the primary engine with `cvss4py` [14] (pinned commit `9fe705c`) across the official FIRST corpus ($N = 486,472$). To prevent data snooping, the protocol decouples numeric score concordance ($D_{\text{numeric}} = 461,444$) from negative syntax validation ($D_{\text{validation}} = 25,028$). Furthermore, to evaluate generalization, an external held-out corpus of $N = 938$ real-world advisories was acquired from the GitHub Advisory Database [15], cryptographically hashed, and quarantined under commit-level locks prior to first evaluation.

G. Human Authorization Checkpoint

Every scenario requires review. The reviewer can accept, modify, reject, or defer a recommendation. The workflow's governance model requires the final record to retain the original candidate, the reviewer state, and the evidence available at assessment time.

This checkpoint limits automation bias by making uncertainty and provenance visible. It also supports later comparison between watcher recommendations and expert assessments, which is planned as future work.

H. Trace and Export Layer

Each scenario produces a trace artifact containing source metadata, evidence, candidate decisions, uncertainty, and review state. Dataset-level scripts generate CSV, JSON, Markdown, LaTeX, validation metrics, and summary tables. The exported artifacts provide a reproducible snapshot of the workflow state.

V. Dataset and Experimental Method

A. Validation Structure and Separation

The evaluation is structured into two strictly separated tiers: specification-level conformance verification and controlled workflow evaluation. Specification-level verification evaluates whether the scoring engine adheres to the CVSS v4.0 mathematical standard and maintains formal monotonicity properties. Controlled workflow evaluation assesses whether the evidence normalization pipeline successfully structures evidence, flags uncertainty, enforces human authorization requirements as a governance constraint, and exports reproducible artifacts across curated scenarios.

B. Specification-Level Verification Design

To establish an exhaustive reference-conformance-tested baseline prior to evaluating the operational workflow, the deterministic scoring core was evaluated against the official FIRST reference corpus Round 5, comprising 486,472 vectors evaluated against pinned FIRST commit `d766d0c8ab4368b67bf27dd0e411eb481f05fdbb`.
In addition, a metamorphic testing campaign evaluated 10,000 executions across four metamorphic relations: MR-1 (monotonicity of criticality), MR-2 (defense removal monotonicity), MR-3 (context permutation invariance), and MR-4 (irrelevant control invariance). Specification-level verification establishes arithmetic conformance to published standards; it does not evaluate contextual suitability or operational effectiveness in production.

C. Formal Specification of Metamorphic Relations

Let $\mathcal{V}$ denote the space of valid CVSS v4.0 Base vectors, $\mathcal{E}$ the space of structured environmental evidence contexts, and $f : \mathcal{V} \times \mathcal{E} \to \mathbb{R} \times \mathcal{M}$ the deterministic evaluation pipeline returning an Environmental score $S(v, e) \in [0.0, 10.0]$ and candidate modified metrics $M(v, e) \in \mathcal{M}$. The campaign (Campaign ID: `HELPUS-METAMORPHIC-10K-G9B`) evaluated 10,000 executions ($2,500$ per relation) across four formal relations:

1) **MR-1 (Monotonicity of Criticality):** Let $e \in \mathcal{E}$ have security requirements $R \in \{\text{CR}, \text{IR}, \text{AR}\}$ ordered as L $<$ M $<$ H. Let $T_{\text{MR1}}(e)$ elevate one or more requirements to $R' > R$ ceteris paribus.

$$S(v, T_{\text{MR1}}(e)) \geq S(v, e) \tag{2}$$

Violation criterion: $S(v, T_{\text{MR1}}(e)) < S(v, e)$.

2) **MR-2 (Defense Removal Monotonicity):** Let $e_{\text{def}} \in \mathcal{E}$ specify reachability under active defense or isolation (reachability $\in$ {ADJACENT_ONLY, LOCAL_ONLY, PHYSICAL_ONLY}). Let $T_{\text{MR2}}(e_{\text{def}}) = e_{\text{unprot}}$ remove network defenses (reachability = PUBLIC_ROUTED, internet_exposed = True).

$$S(v, T_{\text{MR2}}(e_{\text{def}})) \geq S(v, e_{\text{def}}) \tag{3}$$

Violation criterion: $S(v, T_{\text{MR2}}(e_{\text{def}})) < S(v, e_{\text{def}})$.

3) **MR-3 (Context Permutation Invariance):** Let $\sigma = \langle (k_1, v_1), \ldots, (k_n, v_n) \rangle \in \text{Seq}(\mathcal{E})$ be an ordered serialization of evidence key-value pairs ingested by the workflow, and let $\pi \in S_n$ be an arbitrary permutation representing an alternate arrival or serialization order of the same logical evidence.

$$S(v, \pi(\sigma)) = S(v, \sigma) \quad \wedge \quad M(v, \pi(\sigma)) = M(v, \sigma) \tag{4}$$

Violation criterion: $S(v, \pi(\sigma)) \neq S(v, \sigma) \vee M(v, \pi(\sigma)) \neq M(v, \sigma)$.

4) **MR-4 (Irrelevant Evidence Invariance):** Let $\mathcal{K}$ be the universe of evidence keys, $K_{\text{rel}} \subset \mathcal{K}$ the subset consumed by the environmental resolver, and I an orthogonal evidence record whose keys satisfy keys$(I) \subseteq \mathcal{K} \setminus K_{\text{rel}}$ (e.g., unrelated operational logs, maintenance timestamps).

$$S(v, e \oplus I) = S(v, e) \quad \wedge \quad M(v, e \oplus I) = M(v, e) \tag{5}$$

Violation criterion: $S(v, e \oplus I) \neq S(v, e) \vee M(v, e \oplus I) \neq M(v, e)$.

These relations characterize verified invariants within the finite campaign ($2,500$ executions per relation, zero violations); they do not constitute an exhaustive universal mathematical proof across infinite input spaces.

D. Unit of Analysis

The unit of analysis is an environmental assessment scenario. A scenario combines a vulnerability severity baseline with a consumer deployment context and a candidate Environmental assessment. Scenarios are evaluated as workflow records rather than independent observations of production risk.

E. Hybrid Dataset

The dataset contains 30 scenarios. 12 scenarios use real NVD records carrying CVSS v4.0 Base information [16], [17], [18], [19], [20], [21], [22], [23], [24], [25], [26], [27]. The remaining 18 scenarios are curated synthetic cases designed to exercise contextual differences.

The hybrid design provides two kinds of control. Real NVD records preserve authentic vulnerability identifiers, Base vectors, and source metadata. Synthetic cases allow deliberate variation of context without implying that the scenario corresponds to an observed production deployment.

The Environmental context associated with the NVD rows is curated locally. NVD supplies vulnerability information, not the consumer organization's asset criticality, compensating controls, or mission requirements. The manuscript and dataset label this boundary explicitly.

F. Scenario Construction

Scenario construction follows four steps. First, the pipeline selects or creates a Base vulnerability record. Second, it assigns a consumer context template describing asset role, exposure, and security requirements. Third, it generates candidate modified metrics and a rationale. Fourth, it exports an uncertainty flag and review-required state.

The synthetic scenarios are not intended to simulate the statistical distribution of enterprise assets. They are controlled test cases for the workflow schema and validators. Similarly, the NVD sample is time-bounded and is not claimed to represent the population of CVSS v4.0 vulnerabilities. The benchmark is a verification corpus rather than a statistical sample. Its purpose is to exercise the trace schema, deterministic policy logic, verification mechanisms, and governance gates across heterogeneous asset profiles. It is not intended to support population-level inference, and no statistical generalization claim in this study depends on the corpus size.

G. Measures

Evidence coverage is the percentage of scenarios containing the required evidence representation. Trace completeness is the percentage containing the required per-scenario trace structure. Review coverage reports the presence of a human-review state. Uncertainty coverage reports whether uncertainty is represented explicitly.

Context sensitivity is measured by comparing the Base-only operational priority P_{base} with the Environmental-aware operational priority P_{env}. Priorities belong to the ordered set:

$$\mathcal{P} = \langle \text{defer}, \text{low}, \text{medium}, \text{high}, \text{critical} \rangle \tag{6}$$

with the bijective ordinal mapping $g : \mathcal{P} \to \{0, 1, 2, 3, 4\}$ defined as:

$$g(p) = \begin{cases} 0, & p = \text{defer} \\ 1, & p = \text{low} \\ 2, & p = \text{medium} \\ 3, & p = \text{high} \\ 4, & p = \text{critical} \end{cases} \tag{7}$$

The base priority $P_{\text{base}} \in \{\text{defer}, \text{low}, \text{medium}, \text{high}, \text{critical}\}$ is mapped from the official qualitative severity of the Base score S_{base} via $P_{\text{base}} = \text{severity}(S_{\text{base}})$. Consumer-side operational prioritization derives the contextual priority P_{env} via a deterministic policy function $h(P_{\text{base}}, e)$ defined over the deployment context e:

$$g(P_{\text{env}}) = \min(4, \max(0, g(P_{\text{base}}) + w_{\text{context}}(e) + w_{\text{control}}(e))) \tag{8}$$

where $w_{\text{context}}(e) \in \{-2, 0, 1, 2, 3\}$ is determined by the deployment environment profile ($+3$ for public API gateways, $+2$ for customer-facing web applications, identity providers, backend databases, and OT monitoring gateways, $+1$ for developer workstations, 0 for internal administrative consoles, and -2 for isolated lab systems), and $w_{\text{control}}(e) \in \{-1, 0\}$ reflects active compensating controls (-1 when controls such as network isolation, WAF, or multi-factor authentication are present; 0 when unconstrained).

These weights encode explicit policy design choices rather than parameters estimated from data. Section VI-I therefore evaluates deterministic local sensitivity within the declared discrete weight domain rather than statistical uncertainty or predictive robustness.

The Category Delta Δ_{cat} for a scenario is formally defined as:

$$\Delta_{\text{cat}} = g(P_{\text{env}}) - g(P_{\text{base}}) \tag{9}$$

where $\Delta_{\text{cat}} > 0$ denotes priority escalation (up to $+2$), $\Delta_{\text{cat}} < 0$ denotes priority de-escalation (down to -3), and $\Delta_{\text{cat}} = 0$ denotes unchanged priority. Across the $N = 30$ curated scenarios, the sample mean category delta is:

$$\bar{\Delta}_{\text{cat}} = \frac{1}{N} \sum_{i=1}^{N} \Delta_{\text{cat}}^{(i)} = \frac{6.0}{30} = 0.2 \tag{10}$$

confirming the exact empirical summary reported in the dataset metrics. The priority categories are prototype workflow labels, and their numeric difference is a custom category delta rather than an official CVSS specification metric. This formal separation explains why in Table V several CVEs exhibit a numeric score delta of 0.0 while undergoing an operational priority shift ($\Delta_{\text{cat}} = \pm 1$): S_{env} is governed strictly by the official FIRST MacroVector equivalence classes, whereas P_{env} incorporates consumer-side deployment exposure and compensating control policy weights outside the CVSS scoring engine. Furthermore, the corrected domain $w_{\text{context}} \in \{-2, 0, 1, 2, 3\}$ and $w_{\text{control}} \in \{-1, 0\}$ mathematically reproduces the full range of observed deltas $[-3, +2]$, including the de-escalations high→defer ($\Delta_{\text{cat}} = -3$ in SCN-SYN-014) and medium→defer ($\Delta_{\text{cat}} = -2$

TABLE II
DATASET AND WORKFLOW SUMMARY

Measure	Value
Scenarios	30
NVD/CVSS v4.0 records	12
Curated synthetic scenarios	18
Evidence coverage	100.00%
Trace completeness	100.00%
Explicit uncertainty fields	30/30
Operational priority shifts	22/30 (73.33%)

in SCN-SYN-022) resulting from isolated non-production deployment ($w_{\text{context}} = -2, w_{\text{control}} = -1$).

H. Validation Procedure

Validation is automated at multiple levels. Schema checks verify required fields and permitted source labels. Documentation checks verify claim boundaries. Result validators compare generated summaries with dataset-level metrics. LaTeX validation checks required sections, double-blind controls, bibliography keys, and forbidden claims. The PDF build uses `pdflatex`, `bibtex`, and repeated `pdflatex` passes to resolve citations.

VI. RESULTS

A. Specification Conformance and Metamorphic Results

Specification-level evaluation demonstrated 100.00% arithmetic conformance with the official standard: 486,472 of 486,472 vectors in the FIRST reference corpus Round 5 passed with zero arithmetic divergences against pinned commit `d766d0c8ab4368b67bf27dd0e411eb481f05fdbb`. In the metamorphic testing campaign, 10,000 executions completed with zero invariant violations across all four relations (MR-1: 2,500/2,500; MR-2: 2,500/2,500; MR-3: 2,500/2,500; MR-4: 2,500/2,500; campaign ID `HELPUS-METAMORPHIC-10K-G9B`, verdict: PASSED). These results confirm that the underlying scoring core behaves as a deterministic and specification-conformant calculator across the reference corpus, providing a verified foundation for empirical workflow evaluation without claiming unconstrained universal monotonicity across untested inputs.

B. Empirical Artifact Completeness and Traceability

All 30 scenarios contain evidence summaries and trace artifacts. Evidence coverage was 100.00 percent and trace completeness was 100.00 percent. All scenarios include an explicit review requirement, and uncertainty is represented in the scenario records.

These findings answer RQ1 at the workflow level: the prototype can generate the required artifacts consistently for the evaluated dataset. They do not establish that every candidate metric is semantically correct.

TABLE III
OPERATIONAL PRIORITY TRANSITIONS

Base priority	Environmental-aware priority	Count
critical	critical	3
high	critical	4
high	defer	1
high	high	2
high	medium	2
low	defer	2
low	high	1
low	low	1
low	medium	1
medium	critical	2
medium	defer	1
medium	high	6
medium	low	2
medium	medium	2

TABLE IV
CVSS-B SEVERITY DISTRIBUTION

Severity	Count
CRITICAL	3
HIGH	9
LOW	5
MEDIUM	13

C. Context-Sensitive Priority Transitions

Operational priority changed in 22 of 30 scenarios (73.33 percent), while 8 scenarios retained the same category. The average category delta was 0.2. The observed range was -3.0 to 2.0.

Table III shows the transition distribution. Both upward and downward transitions are meaningful in the workflow. An upward transition can represent high local security requirements or more adverse deployment conditions. A downward transition can represent isolation, reduced requirements, or effective compensating conditions. Neither transition changes the official Base record.

The result supports RQ2 by showing that explicit consumer context can alter the prototype's operational ordering. Because contexts were curated, the result is a demonstration of sensitivity rather than evidence of real-world outcome improvement.

D. Severity Distribution

Table IV reports the Base severity distribution. This distribution is retained separately from operational transitions so that a reader can distinguish vulnerability severity from consumer prioritization.

E. Controlled Workflow Evaluation on Real NVD CVEs

The controlled workflow evaluation incorporates 12 real CVE records from the National Vulnerability Database

TABLE V
CONTROLLED WORKFLOW EVALUATION ON 12 REAL NVD CVES (CURATED BENCHMARK, NOT AN INDEPENDENT EFFICACY SAMPLE)

CVE ID	Input Type	Input	Context Type	Context	Score Δ	Priority Shift (Δ_{cat})
CVE-2026-4251	CVSS-BT	1.1	CVSS-BTE	1.1	0.0	low → low (0)
CVE-2026-4252	CVSS-BT	8.9	CVSS-BTE	8.8	-0.1	high → medium (-1)
CVE-2026-4270	CVSS-B	6.8	CVSS-BE	6.8	0.0	medium → high (+1)
CVE-2026-28490	CVSS-B	8.3	CVSS-BE	8.3	0.0	high → critical (+1)
CVE-2026-28498	CVSS-B	8.2	CVSS-BE	8.1	-0.1	high → high (0)
CVE-2026-29510	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → low (-1)
CVE-2026-29513	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → medium (0)
CVE-2026-29520	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → high (+1)
CVE-2026-29521	CVSS-B	5.1	CVSS-BE	5.1	0.0	medium → high (+1)
CVE-2026-3644	CVSS-B	6.0	CVSS-BE	5.9	-0.1	medium → low (-1)
CVE-2026-4224	CVSS-B	6.0	CVSS-BE	6.0	0.0	medium → high (+1)
CVE-2026-4253	CVSS-BT	2.0	CVSS-BTE	2.0	0.0	low → medium (+1)

(NVD) published with official CVSS v4.0 metrics, paired with curated organizational deployment contexts. Table V details the 12 cases, reporting the official input score and nomenclature (CVSS-B or CVSS-BT), contextual score and nomenclature (CVSS-BE or CVSS-BTE), numeric score delta, and operational priority shift (Δ_{cat}). This curated benchmark demonstrates operational workflow sensitivity under realistic vulnerability data rather than an independent sample of operational efficacy. Full 30-metric Base and Environmental vectors for all 12 cases are preserved in the reproducibility trace repository (`validation/article/trace/SCN-NVD-001.json` through `SCN-NVD-012.json`) and `data/article/cvss40_environmental_scenarios.csv`.

F. Trace Governance and Machine-Checkable State

The workflow deterministically encodes evidence provenance, uncertainty, and human authorization states in structured trace artifacts rather than exporting only an ungrounded score or category. To audit this structure independently, an automated trace verifier was executed against the benchmark corpus. Across all 30 canonical scenarios (12 curated NVD records and 18 synthetic test cases, with 12 out-of-scope legacy files segregated without benchmark contamination), the verifier demonstrated 30/30 canonical PASS (canonical failures = 0, overall status = PASS), validating 464 discrete checks across three categories:

- **Structural Integrity (240 checks, 0 failures):** Verified top-level schema conformance, required nested environmental evidence structures, mandatory boundary disclaimers, explicit uncertainty representation, and strict enforcement of the non-autonomous human review gatekeeper status (`human_review_status = "required"`).
- **Arithmetic and Policy Recomputation (128 checks, 0 failures):** Recomputed Base priority mapping $P_{\text{base}} = f(\text{Severity})$, Category Delta arithmetic $\Delta_{\text{cat}} = g(P_{\text{env}}) - g(P_{\text{base}})$, ordinal bounded range clamp $g(P_{\text{env}}) \in [0, 4]$, and nominal policy profile lookup decoupled via the canonical policy module (`core.cvss40_environmental_policy`).
- **Cross-Artifact Consistency (96 checks, 0 failures):** Enforced epistemological source separation (NVD Base scores recomputed via the canonical parser/scorer `core.cvss40`, whereas synthetic scenarios strictly validated CVSS v4.0 vector grammar and uncertainty disclaimers without treating assigned vectors as official reference specification) and cross-referenced all metadata against the canonical scenario dataset.

The evaluation recorded 34 structured schema limitations, isolated from failures: 30 instances reflect that the current schema provides narrative evidence fields rather than atomic, machine-addressable linkage between each candidate modified metric and its corresponding evidence item; and four instances correspond to curated deployment adjustments in NVD scenarios (`SCN-NVD-001`, `SCN-NVD-006`, `SCN-NVD-007`, and `SCN-NVD-008`).

Specifically, the framework deterministically verifies Base-priority mapping, Category-Delta arithmetic, and nominal policy lookup. Operational priority matches the nominal policy profile in 26 of 30 scenarios. In four curated NVD scenarios (SCN-NVD-001, SCN-NVD-006, SCN-NVD-007, and SCN-NVD-008), deployment-specific constraints recorded in narrative evidence introduce a curated adjustment; the verifier records this as a schema limitation rather than treating the adjustment as silently recomputed from structured weights. In these four cases, the stored operational value is not deterministically recomputable from structured sub-weights because the local trade-off is recorded in narrative prose; the verification instead validates nominal policy derivation combined with declared curated deviation and consistency cross-validation.

These results provide empirical evidence for RQ3, demonstrating machine-checkable conformance with declared provenance, schema, policy-recomputation, uncertainty, and vector-validity constraints. Crucially, this conformance does not establish semantic correctness of the contextual choices, nor does it replace independent expert adjudication.

G. Empirical Mutation Testing of the Trace Verifier

To evaluate whether the independent trace verifier reliably detects violations of declared schema, arithmetic, governance, and provenance constraints, we conducted an empirical mutation testing campaign. The evaluation targeted six representative benchmark scenarios: three curated NVD records (`SCN-NVD-001`, `SCN-NVD-003`, and `SCN-NVD-007`, spanning both curated overrides and nominal matches) and three synthetic test cases (`SCN-SYN-013`, `SCN-SYN-020`, and `SCN-SYN-028`).

As an essential campaign integrity pre-condition, all six unmodified control traces were verified prior to mutation, demonstrating 6/6 PASS with zero failures. Cryptographic SHA-256 digests of the canonical trace files were recorded before and verified byte-identical after the campaign, confirming zero modification to the underlying benchmark artifacts.

We formulated eight deterministic mutation operators ($M1$–$M8$) reflecting distinct constraint failure modes:

Across 48 planned cases, 42 mutations were applicable and six were marked not applicable by design ($M4$ on synthetic

TABLE VI
EMPIRICAL MUTATION TESTING RESULTS FOR THE INDEPENDENT TRACE VERIFIER

Operator	Injected Violation Class	Applicable	Detected	Missed	Detection Rate
M1	Structural: Remove mandatory top-level field (`boundary`)	6	6	0	100.0%
M2	Arithmetic: Category delta mismatch (Δ_{cat} corrupted to $+4$)	6	6	0	100.0%
M3	Vector syntax: Corrupted CVSS v4.0 vector string grammar	6	6	0	100.0%
M4	Scorer recomputation: Altered Base score in NVD trace (9.9 vs vector)*	3	3	0	100.0%
M5	Governance/Uncertainty: Blanked uncertainty flags in synthetic trace†	3	3	0	100.0%
M6	Authorization state: Forbidden review bypass (`bypassed`)	6	6	0	100.0%
M7	Provenance: Source separation contamination (cross-origin CVE/source tag)	6	6	0	100.0%
M8	Cross-artifact: Inconsistent Base severity vs reference CSV	6	6	0	100.0%
Total	Evaluated Mutation Campaign	42	42	0	100.0%

*M4 is applicable strictly to NVD records with official scores; marked not applicable (N/A) for 3 synthetic cases. †M5 is applicable strictly to synthetic cases requiring non-official disclaimers; marked N/A for 3 NVD cases. All six N/A cases are excluded from the detection rate denominator.

records and $M5$ on NVD records). Detection semantics strictly required both that the verifier reject the mutated trace and that the operator-specific expected check appear among the recorded failures. The verifier rejected all 42 applicable mutants through their respective expected checks, achieving 42/42 detections (100.0%) with 0 missed and 0 unexpected outcomes across both NVD (21/21) and synthetic (21/21) partitions.

Empirical mutation testing provides empirical evidence that injected trace violations are detected and rejected in the evaluated mutation set. It does not constitute a mathematical proof, proof of semantic correctness, a completeness guarantee, or exhaustive coverage.

H. Verifier-Agnostic Randomized Mutation Complement

To evaluate verifier sensitivity without operator-selection bias and complement the structured mutation campaign ($M1$–$M8$), we implemented an independent, verifier-agnostic randomized mutation generator. The generator was authored in a separate utility without importing verifier assertion maps, check identifiers, or internal verification catalogs. We use the term verifier-agnostic strictly to denote implementation independence from verifier internals: the generator does not import assertion identifiers, consult the verifier's check catalog, or inspect expected failure messages. The term does not imply conceptual independence from the authors' design choices; the $F1$–$F9$ mutation-family taxonomy remains author-defined and is treated as a threat to validity. Using a published, reproducible pseudo-random seed (`seed = 20261021`), the tool generated mutations strictly in-memory on deep copies of trace data across the six representative scenarios (`SCN-NVD-001`, `SCN-NVD-003`, `SCN-NVD-007`, `SCN-SYN-013`, `SCN-SYN-020`, and `SCN-SYN-028`). Cryptographic SHA-256 digests of the six canonical trace files on disk were recorded before and verified byte-identical after the campaign.

The generator produced exactly 20 applicable perturbations per scenario across nine verifier-agnostic mutation families ($F1$–$F9$), partitioned into structural corruption ($F1$–$F4$) and field-level corruption ($F5$–$F9$), yielding 120 applicable perturbations total with zero discarded N/A attempts. Each applicable perturbation was submitted to the independent trace verifier. Table VII summarizes the evaluation outcomes.

Across the 120 applicable perturbations, the verifier rejected 83 cases (69.2% overall rejection rate), comprising 43/60 rejected in the NVD partition (71.7%) and 40/60 rejected in the synthetic partition (66.7%). Group-level analysis demonstrated 43/59 rejections (72.9%) for structural corruption and 40/61 rejections (65.6%) for field-level corruption. Across individual mutation families, the verifier achieved 100.0% rejection on top-level required field removals ($F1$: 16/16), subobject removals ($F2$: 12/12), structural type corruptions ($F4$: 15/15), numeric perturbations ($F7$: 10/10), and numeric domain shifts ($F8$: 11/11). Conversely, subobject injections ($F3$: 0/16 rejected) were accepted because current JSON handling deliberately follows open-world semantics and therefore permits undeclared attributes. $F3$ is best interpreted as a design-intent observation rather than an unanticipated verifier failure: whether that tolerance is appropriate for a governance-oriented audit schema remains a policy choice for schema v2, where a closed-world alternative could be evaluated explicitly. String truncations ($F5$: 6/13 rejected, 46.2%) and random string alterations ($F6$: 3/15 rejected, 20.0%) exhibited lower rejection rates because they primarily perturbed unconstrained narrative text fields rather than formal vector grammar. Valid token flips ($F9$) achieved 10/12 rejections (83.3%), rejecting priority and severity inconsistencies while accepting context exposure flips lacking explicit cross-field invariants. Rejections were triggered across three primary failure categories: Consistency (58 rejections), Recomputed Arithmetic/Policy (50 rejections), and Structural Integrity (49 rejections).

The 37 accepted perturbations expose boundaries of the current machine-checkable contract rather than being silently discarded. Sixteen added schema-valid attributes that are permitted by the current open-world JSON handling; nineteen modified free-form narrative fields for which the verifier currently imposes no lexical or semantic constraints; and two flipped `internet_exposure` without violating any currently encoded cross-field invariant. These cases identify concrete specification gaps and future schema-hardening targets, categorized as accepted perturbations outside or at the boundary of the currently encoded verifier constraints. They do not by themselves establish that every accepted perturbation is semantically benign, nor do the rejection results establish completeness or exhaustive fault coverage. The randomized mutation complement provides empirical evidence of verifier sensitivity to independently generated perturbations within the evaluated mutation set. It does not establish completeness, semantic correctness, exhaustive fault coverage, or mathematical proof of correctness.

TABLE VII
VERIFIER-AGNOSTIC RANDOMIZED MUTATION RESULTS ACROSS REPRESENTATIVE SCENARIOS

Group / Evaluation Subset	Applicable	Rejected	Accepted	Rejection Rate
Overall Campaign	120	83	37	69.2%
NVD Partition	60	43	17	71.7%
Synthetic Partition	60	40	20	66.7%
Structural Corruption	59	43	16	72.9%
Field-Level Corruption	61	40	21	65.6%

I. Ablation of Priority Components

To assess the operational contribution of each evidence dimension, we conducted a deterministic ablation study across the $N = 30$ canonical benchmark scenarios (12 curated NVD records and 18 synthetic cases). We evaluated five operational variants against the reference benchmark priority stored in the trace corpus:

- **B0 (Base Severity Only):** Operational priority assigned strictly from base severity, ignoring environmental metrics and policy weights ($P_{B0} = f(\text{Severity})$).
- **B1 (Environmental Score Only):** Operational priority assigned strictly from the CVSS-BE environmental score severity rating without contextual policy weighting.
- **B2 (Context Only):** Policy evaluation incorporating only organizational context evidence (w_{context}), setting controls weight $w_{\text{control}} = 0$.
- **B3 (Controls Only):** Policy evaluation incorporating only mitigating controls evidence (w_{control}), setting context weight $w_{\text{context}} = 0$.
- **B4 (Full Nominal Policy):** Full structured policy evaluation combining context and control weights ($w_{\text{context}} + w_{\text{control}}$) clamped to $[0, 4]$.

Across the 30-scenario controlled benchmark, the full nominal policy (B4) matched the stored operational priority in 26 scenarios (86.7%) and reduced the mean absolute ordinal difference to 0.167, compared with 0.933 for Base Severity Only (B0), 0.967 for Environmental Score Only (B1), 0.700 for Context Only (B2), and 1.300 for Controls Only (B3). In terms of category shifts relative to base severity, B0 produces 0 shifts (0.0%), B1 produces 7 shifts (23.3%), B2 produces 23 shifts (76.7%), B3 produces 27 shifts (90.0%), and B4 produces 24 shifts (80.0%), whereas the reference stored benchmark contains 22 shifts (73.3%).

Partition analysis reveals distinct epistemological profiles across data sources:

- **Curated Real-World Records (NVD, $N = 12$):** The full nominal policy achieves 8/12 exact matches with a mean absolute difference of 0.417 (compared with MAE of 0.750 for B0, 0.750 for B1, 1.083 for B2, and 1.167 for B3). The four B4 divergences correspond exactly to the curated NVD deployment adjustments identified by the trace audit (`SCN-NVD-001`, `SCN-NVD-006`, `SCN-NVD-007`, and `SCN-NVD-008`), where narrative environmental evidence guided operational posture beyond structured sub-weights.
- **Curated Test Cases (Synthetic, $N = 18$):** The full nominal policy achieves 18/18 exact matches with a mean absolute difference of 0.000 (compared with MAE of 1.056 for B0, 1.111 for B1, 0.444 for B2, and 1.389 for B3). Because synthetic scenarios were authored within the same specification rules, this 100% match reflects construction consistency with the benchmark framework rather than independent predictive accuracy.

Ablating context (w_{control} only, B3) and controls (w_{context} only, B2) demonstrates that neither isolated dimension reproduces the operational target, confirming that both context and control evidence contribute to nominal policy resolution. Furthermore, the CVSS-BE score alone (B1) yields only 9/30 exact matches and a slightly higher mean absolute difference (0.967) than base severity alone (0.933), indicating that score modification without explicit policy weighting does not align with operational prioritization.

Crucially, the stored benchmark is the reference target produced under the project's governance framework, not an independent competitive baseline; its 30/30 conformance is tautological by definition. Because the benchmark is endogenous and $N = 30$, these descriptive metrics characterize internal benchmark consistency and component ablation rather than independent predictive validity.

The difference between the 24 category shifts produced by the nominal B4 policy and the 22 shifts recorded in the stored benchmark is explained by the four curated NVD deviations. In `SCN-NVD-001` and `SCN-NVD-007`, the nominal policy produces a category shift relative to Base priority, whereas the stored operational priority returns to the Base-priority category after a documented narrative deployment adjustment. `SCN-NVD-006` and `SCN-NVD-008` remain category shifts under both representations, although their final categories differ. Thus, the two-shift count difference between Sections VI-C and VI-H results from the documented curated adjustments rather than an inconsistency in the reported results.

J. Contextual Priority Sensitivity Stress Test

To evaluate the operational stability of nominal prioritization decisions under local contextual weight uncertainty, we execute a deterministic sensitivity stress test across the 30 canonical benchmark scenarios (12 curated NVD records and 18 synthetic test cases). Because organizational environmental policy in our framework is purely deterministic and rule-based rather than estimated from training data, standard machine

TABLE VIII
ABLATION OF PRIORITY COMPONENTS ON THE CONTROLLED BENCHMARK ($N = 30$)

Variant	Exact Match	Match Rate	Mean Signed Diff	Mean |Diff|	Shifts vs B0
B0 (Base Severity Only)	8/30	26.7%	-0.200	0.933	0/30 (0.0%)
B1 (Environmental Score Only)	9/30	30.0%	-0.167	0.967	7/30 (23.3%)
B2 (Context Only, $w_{\text{control}} = 0$)	11/30	36.7%	+0.633	0.700	23/30 (76.7%)
B3 (Controls Only, $w_{\text{context}} = 0$)	7/30	23.3%	-1.100	1.300	27/30 (90.0%)
B4 (Full Nominal Policy)	26/30	86.7%	+0.100	0.167	24/30 (80.0%)
Reference (Stored Benchmark)*	30/30	100.0%	0.000	0.000	22/30 (73.3%)

*The stored benchmark represents the reference operational priority within the corpus, not an independent competitive baseline. Agreement with it is tautological by construction for synthetic records and reflects benchmark internal consistency.

learning cross-validation (such as Leave-One-Environment-Out) is methodologically inapplicable; instead, local weight perturbation provides an appropriate, conservative assessment of operational stability.

The stress test perturbs policy weights strictly within the declared specification boundaries: $w_{\text{context}} \in \{-2, 0, 1, 2, 3\}$ and $w_{\text{control}} \in \{-1, 0\}$. For each scenario, context weight is systematically varied across its immediate ordinal neighbors in the ordered domain (nearest lower, nominal, and nearest upper value, bounded by $[-2, 3]$), while compensating control weight is evaluated under both nominal and flipped binary states ($-1 \leftrightarrow 0$). The full evaluation grid spans 166 combinations across the 30 scenarios, comprising 30 nominal configurations and 136 strictly perturbed cases (56 on NVD, 80 on synthetic). All ordinal shifts ($\Delta_p = g(P_{\text{env}}^{\text{pert}}) - g(P_{\text{env}}^{\text{nominal}})$) are measured strictly against the unperturbed nominal policy baseline ($B4_{\text{nominal}}$); observed stored priorities ($B4_{\text{observed}}$) are preserved separately for descriptive traceability and are not used as an empirical reference baseline.

Across the 136 strictly perturbed cases (Table IX), 55 perturbations (40.44%) preserved the nominal operational priority category and 81 (59.56%) produced a priority transition (51 upward shifts, 37.50%; 30 downward shifts, 22.06%). However, 121 of 136 perturbations (88.97%) produced an absolute ordinal shift of at most one category ($|\Delta_p| \leq 1$), yielding a mean absolute shift of 0.7132. The distribution of shift magnitudes demonstrates bounded local variance: 55 cases with $|\Delta_p| = 0$, 66 with $|\Delta_p| = 1$, 14 with $|\Delta_p| = 2$, and exactly 1 extreme case with $|\Delta_p| = 3$ (observed in an isolated lab perturbation where maximum context elevation coincided with control removal).

At the scenario level, 28 of 30 scenarios were sensitive to at least one valid local perturbation, while 2 scenarios demonstrated complete local stability under all valid perturbations: `SCN-SYN-019` (identity provider) and `SCN-SYN-025` (public web application). Across asset profiles, `internal_admin_console` exhibited the highest sensitivity rate (90.0% changed, mean $|\Delta_p| = 1.2000$, max 2), followed by `isolated_lab_system` (66.67% changed, mean $|\Delta_p| = 1.0833$, max 3), `developer_workstation` (65.0% changed, mean $|\Delta_p| = 0.7000$, max 2), `public_web_application` (60.0% changed, mean $|\Delta_p| = 0.6500$, max 2), `database_server` (50.0% changed, mean $|\Delta_p| = 0.5500$, max 2), and `ot_monitoring_gateway` (46.67% changed, mean $|\Delta_p| = 0.6000$, max 2); in contrast, `identity_provider` (45.0% changed, mean $|\Delta_p| = 0.4500$, max 1) and `public_api_gateway` (44.44% changed, mean $|\Delta_p| = 0.4444$, max 1) exhibited maximum shifts of at most one rank. The four curated NVD deviations (`SCN-NVD-001`, `SCN-NVD-006`, `SCN-NVD-007`, and `SCN-NVD-008`) were evaluated against their respective $B4_{\text{nominal}}$ targets, confirming that operational adjustments recorded in traces reflect documented governance rationale rather than arithmetic fragility.

These stress test results characterize deterministic sensitivity of nominal operational priority to valid local perturbations of contextual policy weights within the declared policy domain. They do not constitute predictive robustness, statistical robustness, generalization to unseen environments, causal sensitivity, calibrated uncertainty, or a formal robustness proof.

K. Schema v2 Closed-World Compatibility and Replay (T2/T2R, T3)

To address RQ-R6-2, we evaluated backward compatibility and mutation detection under the closed-world Schema v2 contract. In the compatibility evaluation (Experiment T2/T2R), all 30 historical benchmark traces (Dataset B) were evaluated against Schema v2. As formalized in protocol deviation R6-DEV-001, 30/30 historical traces were classified as `V1_VALID_V2_INVALID` (0/30 valid under v2), demonstrating that Schema v2 successfully rejects uncanonicalized legacy formats: 12 NVD records were rejected due to `INVALID_TYPE` (narrative string in `compensating_controls` rather than structured object arrays), and 18 synthetic cases were rejected due to `INVALID_ENUM` (empty string `""` in `cve_id` rather than null or valid CVE pattern). No undeclared fields were observed.

In the historical mutation replay campaign (Experiment T3), all 120 perturbations from the verifier-agnostic complement were resubmitted under Schema v2. Replay achieved 120/120 rejections (100.0%), compared with 83/120 under open-world Schema v1. Crucially, in mutation family $F3$ (subobject injection), Schema v2 achieved 16/16 rejections (100.0%), in stark contrast to 0/16 under Schema v1. This confirms the closed-world hypothesis: prohibiting undeclared properties systematically eliminates silent injection vulnerabilities without modifying scoring logic.

TABLE IX
DETERMINISTIC CONTEXTUAL PRIORITY SENSITIVITY STRESS TEST RESULTS ACROSS 136 VALID LOCAL PERTURBATIONS

Evaluation Partition	Perturbations	Unchanged (%)	Changed (%)	Mean $\lvert\Delta_p\rvert$	Max $\lvert\Delta_p\rvert$	Stable Scenarios
Curated Real-World (NVD)	56	15 (26.79%)	41 (73.21%)	0.8571	2	0/12 (0.0%)
Curated Test Cases (Synthetic)	80	40 (50.00%)	40 (50.00%)	0.6125	3	2/18 (11.1%)
Total Benchmark Corpus	**136**	**55 (40.44%)**	**81 (59.56%)**	**0.7132**	**3**	**2/30 (6.7%)**

Across 136 strictly perturbed cases, 121 (88.97%) resulted in $|\Delta_p| \leq 1$. Directional breakdown: 51 upward shifts (37.50%) and 30 downward shifts (22.06%). All deltas are computed relative to $B4_{\text{nominal}}$. Stable scenarios preserve nominal priority under all valid perturbations in the local grid.

L. Novel Mutation Campaign and Attribution Decoupling (T4, T4R, NF2-R)

To evaluate Schema v2 boundaries against domain-specific faults, we designed six novel mutation families ($NF1$–$NF6$): extension unnamespaced keys ($NF1$), core-field shadowing in extensions ($NF2$), reserved keyword injection ($NF3$), nested array undeclared properties ($NF4$), explicit null on non-nullable scalars ($NF5$), and schema downgrade header injections ($NF6$).

In the initial execution (Experiment T4, $N = 180$), all 180 mutants were rejected by Schema v2. However, methodological auditing revealed that all 30 source parents were legacy traces already invalid under v2; thus, causal fault detection was confounded by pre-existing parent invalidity. In accordance with protocol deviation R6-DEV-002, we preregistered and executed versioned rerun R6.1-T4R on 15 deterministically canonicalized parents ($N = 90$, 15 parents $\times$ 6 families).

In R6.1-T4R, the verifier achieved 75/90 attributable rejections (83.33% overall): $NF1$, $NF3$, $NF4$, $NF5$, and $NF6$ each achieved 15/15 attributable rejections (100.0%). In family $NF2$, 15/15 mutants were accepted by the primary schema because extensions allow arbitrary sub-objects under their isolated namespace. To test this specific boundary without confounding, we executed companion experiment R6.1-T4R-NF2R ($N = 15$), verifying that when core fields are shadowed directly within the closed-world root, 15/15 are rejected under error category `UNKNOWN_FIELD`. Methodologically, T4R ($75/90$) and NF2-R ($15/15$) represent decoupled test suites and are retained as separate denominators rather than summed into an invalid aggregate.

M. Governance Override Invariants and Representability (T5, T5-R, T6)

To address RQ-R6-3, we evaluated the Governance Override layer across eight adversarial operational fixtures (Experiment T5/T5-R). In initial execution T5, seven fixtures passed all checks, but fixture T5.8 failed due to an injected baseline priority mismatch (injected nominal Low vs Eq. 8 calculated Medium). Protocol deviation R6-DEV-003 established that this failure was an oracle/fixture defect rather than an architectural violation. Rerun R6.1-T5R achieved 8/8 PASS (100.0%), confirming complete adherence to all eight governance invariants (INV-G1 through INV-G8). Crucially, Equation 8 nominal formula parameters remained identical, and autonomous overrides were zero across all fixtures.

TABLE X
DIFFERENTIAL VALIDATION RESULTS AGAINST `cvss4py` ON FIRST CORPUS

Evaluation Dimension	Count	Percentage
Numeric Endpoint (D_{numeric})	**461,444**	**100.0000%**
Exact Numeric Score Match	454,047	98.3970%
Score Mismatch ($\lvert\Delta\rvert = 0.1$)	7,397	1.6030%
Validity Disagreement	0	0.0000%
Execution / System Error	0	0.0000%
Validation Endpoint ($D_{\text{validation}}$)	**25,028**	**100.0000%**
Syntax Rejection Concordance	25,028	100.0000%
Negative Validity Disagreement	0	0.0000%
Negative Execution Error	0	0.0000%
Deterministic Rerun Parity	**Pass**	**Run 1 $\equiv$ Run 2**

In Experiment T6, we evaluated the representability of four curated NVD CVEs exhibiting narrative deployment adjustments (`SCN-NVD-001`, `SCN-NVD-003`, `SCN-NVD-007`, and `SCN-NVD-011`) across 12 diagnostic checks. Under pure schema-only representation, 0/4 cases could represent narrative adjustments without information loss. Under the composite architecture combining Schema v2 with downstream governance override, 2/4 cases (`SCN-NVD-001` and `SCN-NVD-007`) were fully represented through normative structural transformation. The remaining 2/4 cases (`SCN-NVD-003` and `SCN-NVD-011`) could not be represented without acquiring new operational evidence. Zero data were invented across all 12 diagnostic checks, demonstrating that the governance override provides auditable expressiveness without speculative data fabrication.

N. Independent Differential Validation (Differential R2)

To address RQ-R6-4, we conducted an exhaustive differential testing campaign comparing our primary scoring engine with `cvss4py` [14] across all 486,472 vectors in the FIRST reference corpus. Following protocol deviations R6-DEV-004 and R6-DEV-005, the evaluation decoupled valid vector scoring from syntax error rejection to prevent category masking.

As detailed in Table X, on the calculable vector subset ($D_{\text{numeric}} = 461,444$), the primary scorer achieved 454,047 exact score matches (98.3970%) with zero validity disagreements and zero runtime errors. All 7,397 observed score mismatches (1.6030%) exhibited an absolute difference of exactly $|\Delta| = 0.1$. In-depth audit confirmed that for 100% of these 7,397 cases, the score computed by our engine

TABLE XI
HELD-OUT TRANSFER EVALUATION RESULTS ON UNSEEN ADVISORIES ($N = 938$)

Classification / Invariant Outcome	Count	Percentage
Nominal-Calculable (Complete Evidence)	339	36.1407%
Fail-Closed Rejections (Missing Evidence)	599	63.8593%
Structural Invalidity Rejections	0	0.0000%
Unresolved Insufficient Information	0	0.0000%
Execution / Environment Errors	0	0.0000%
Information Invented	0	Verified
Autonomous Overrides Attempted	0	Verified
Independent Trace Verifier Status	938/938	100.0% Pass
Diagnostic Checks Evaluated	3,232	Verified
Deterministic Rerun Parity	Pass	Run 1 ≡ Run 2

matches the official FIRST reference score; the discrepancy stems from MacroVector equivalence class interpolation differences in the secondary comparator. On the negative vector subset ($D_{\text{validation}} = 25,028$), both implementations achieved 25,028/25,028 syntax rejection concordance (100.0%). A full duplicate pass confirmed bit-for-bit deterministic rerun parity (`Run 1 ≡ Run 2`).

O. External Held-Out Transfer Evaluation (T7)

To address RQ-R6-1, we evaluated the transferability of the machine-checkable verification contract on an unseen held-out corpus of $N = 938$ real-world vulnerability advisories collected from the GitHub Advisory Database [15] (published between September 1 and October 1, 2026). The corpus was collected, deduplicated (9 exclusions from 947 raw candidates, zero overlap with historical R5 data), and quarantined under commit-level cryptographic locks before any experimental access.

As summarized in Table XI, the workflow classified 339 advisories as nominal-calculable (36.1407%), where complete CVSS v4.0 environmental context was present. For the remaining 599 advisories (63.8593%), the workflow executed fail-closed rejections (`MISSING_MANDATORY_EVIDENCE_REJECTED`) due to incomplete deployment telemetry. Crucially, zero information was invented to force a score, and zero autonomous overrides were attempted. The independent trace verifier validated all 938 generated traces across 3,232 machine-checkable diagnostic checks with zero verification failures. An independent dual-pass execution verified complete deterministic parity. The 599 fail-closed outcomes reflect strict enforcement of evidence requirements rather than pipeline failure, demonstrating that the workflow abstains reliably when operational context is incomplete.

P. Methodological Protocol Deviations (R6-DEV-001–005)

To ensure reproducibility and research integrity, all methodological adjustments during the R6 campaign were pre-registered in a formal deviation log prior to continuation. Table XII summarizes deviations R6-DEV-001 through R6-DEV-005.

VII. DISCUSSION

A. Completeness Versus Correctness

The strongest result is artifact completeness. Every scenario passed evidence and trace validation. This is necessary for reproducibility, but it is not sufficient for correctness. A completely documented recommendation can still contain an incorrect metric interpretation. Future expert evaluation must therefore assess semantic agreement separately from schema completeness.

This distinction is particularly important for automated workflows. Fluent narrative is not evidence of correctness. The architecture requires structured sources, uncertainty fields, and human authorization checkpoints to reduce the risk that generated explanations are mistaken for authoritative decisions.

Of the 34 schema limitations identified by the independent trace verifier, 30 arise because evidence is represented through narrative fields rather than atomic, machine-addressable records linked to individual modified metrics. The remaining four correspond to curated NVD scenarios (`SCN-NVD-001`, `SCN-NVD-006`, `SCN-NVD-007`, and `SCN-NVD-008`) in which deployment-specific narrative adjustments cannot be deterministically reconstructed from the structured policy weights alone. This is an architectural limitation rather than an arithmetic verification failure. A future schema revision should require each candidate modified metric to reference a structured evidence record through a stable evidence identifier, extending machine-checkability to the evidence-to-metric boundary and reducing reliance on narrative-only adjustments.

The empirical results of the randomized mutation complement directly motivated our architectural formulation of Schema v2 as a closed-world contract. In the R6 campaign, closed-world Schema v2 was evaluated not as a retroactive bugfix of R5, but as a distinct governance hypothesis: prohibiting undeclared properties systematically eliminates subobject injections (16/16 rejections in replay) and enforces rigorous field typing. Similarly, the downstream governance override contract establishes an auditable bridge between operational requirements and formal scoring, ensuring that deviations require explicit human authorization while Equation 8 nominal weights remain mathematically invariant.

B. Relationship to Other Prioritization Signals

The workflow complements rather than replaces exploit prediction and stakeholder decision models. EPSS can contribute time-sensitive threat probability. SSVC can contribute stakeholder-specific decision logic. Asset management can contribute exposure and mission context. CVSS Environmental metrics provide a standardized location for selected consumer-side conditions.

A practical implementation could ingest those signals while preserving their distinct meanings. Combining them into an unlabeled composite number would reduce interpretability. The proposed artifact instead records the evidence source and the role it played in the recommendation.

TABLE XII
SUMMARY OF FORMAL PROTOCOL DEVIATIONS IN R6-A1 EXPERIMENTAL CAMPAIGN

Deviation ID	Classification	Affected Phase	Target RQ	Methodological Rationale and Resolution
R6-DEV-001	POST_RESULT_CHANGE	T2 Compatibility	RQ-R6-2	Refined 4-category taxonomy to orthogonal 5-state model after observing 30/30 legacy traces rejected under v2 type/enum constraints; original T2 results frozen.
R6-DEV-002	POST_RESULT_CHANGE	T4 Mutations	RQ-R6-2	Identified valid-parent confounding in T4 ($N = 180$); executed versioned rerun R6.1-T4R on 15 canonical parents ($N = 90$) with companion NF2-R ($N = 15$).
R6-DEV-003	POST_RESULT_CHANGE	T5 Governance	RQ-R6-3	Diagnosed fixture T5.8 failure as baseline priority injected defect; executed versioned rerun R6.1-T5R (8/8 Pass) preserving original T5 (7/8) as historical record.
R6-DEV-004	PRE_RESULT_CHANGE	Differential R1	RQ-R6-4	Clarified primary measurement endpoint as exact numeric score concordance and removed comparator serialization requirement prior to observing results.
R6-DEV-005	POST_RESULT_CHANGE	Differential R2	RQ-R6-4	Decoupled calculable vectors ($D_{\text{numeric}} = 461,444$) from syntax rejection tests ($D_{\text{validation}} = 25,028$); executed corrected protocol R6.2-DIFF-R2.

C. Operational Use

An organization could deploy the workflow between vulnerability ingestion and ticket creation. New CVE data would initialize the Base record. Asset and control evidence would populate the context model. The watcher would prepare a candidate assessment and route it to an analyst. After review, the approved record could inform remediation queues and service-level decisions.

The current prototype does not implement this production integration. Its value is the validated data contract and trace package needed before such an integration can be evaluated safely.

D. Governance and Automation Boundaries

The watcher must not silently overwrite official Base information, convert missing data into confident values, or treat a recommendation as reviewed. Sources should carry retrieval timestamps and provenance. Time-sensitive evidence should expire or be flagged for refresh. Conflicting observations should increase uncertainty rather than be resolved invisibly.

Human authority should also be represented as data. A production version would record reviewer identity or role, timestamp, decision, changes, and rationale. Double-blind research artifacts omit personal identifiers, but the workflow design retains the concept of accountable review.

The governance model strictly isolates active operational assets from unexecuted confirmatory protocols. The confirmatory protocol G10B remains explicitly in a defined but unexecuted state. Correspondingly, held-out confirmatory benchmark datasets C1 (real-world cases) and C2 (adversarial/metamorphic cases) remain sealed and unexecuted under a pre-registered fail-closed gatekeeper (`scripts/g10b_confirmatory_gate.py`) to enforce a strict no-retuning constraint. They will not be inspected or executed without formal gatekeeper release and explicit operational authorization.

Furthermore, independent human expert adjudication has not yet been concluded. The research package includes a pre-registered blinded evaluation protocol (`article/expert_review/`), but claims no completed expert agreement or inter-rater reliability. The empirical results presented in this paper reflect solely the descriptive evaluation of the 30 curated scenarios.

VIII. THREATS TO VALIDITY

A. Construct Validity

Evidence coverage and trace completeness measure the presence of artifacts, not their truth. Operational priority is a prototype category and is not an official CVSS score. The evaluation therefore avoids interpreting the category delta as a measurement of risk reduction.

B. Internal Validity

Scenario logic and context assignment were curated by the project. This introduces construction bias (endogenous validation): because the 30 scenarios (12 real NVD records with CVSS v4.0 data and 18 curated synthetic cases) were designed to exercise schema coverage, field boundaries, and priority transitions, the 100.00% evidence coverage, 100.00% trace completeness, and observed priority transitions reflect designed capability rather than an independent natural distribution. Similarly, the ablation results evaluate internal benchmark consistency under a shared governance framework; the agreement between nominal policy and stored operational priority represents component consistency rather than independent external validation. Furthermore, the mutation testing operators represent intentionally selected perturbations against declared schema invariants; high detection demonstrates verifier sensitivity to those injected fault classes only, and does not establish completeness against unknown fault classes or semantic correctness of the evidence. Similarly, the contextual priority sensitivity stress test evaluates deterministic local stability under valid parameter perturbations bounded by the declared

specification domain; profile weights represent deterministic design choices rather than estimated random variables, and the results do not estimate population robustness, calibrated uncertainty, or statistical generalization. They demonstrate that the workflow schema, ingestion pipeline, and governance gates function as designed across diverse asset profiles, but do not establish independent empirical proof of predictive superiority, operational accuracy, or real-world risk reduction. Independent expert adjudication is required to test whether analysts agree with candidate metrics.

The verifier-agnostic randomized mutation complement is subject to specific methodological threats. Although fully reproducible under `seed = 20261021`, evaluating a single seed does not characterize the full space of possible random perturbations. The six representative scenarios constitute a controlled verification subset rather than a statistical sample of enterprise vulnerabilities. Furthermore, while the generator operates independently without verifier assertion maps, the mutation family taxonomies were defined by the authors; generation is verifier-agnostic, but this does not render the evaluation unbiased. In addition, the 37 accepted perturbations lack an independent semantic oracle, precluding definitive determination of whether accepted cases represent false negatives. Rejection rates measure verifier sensitivity within the evaluated randomized mutation set; they do not measure semantic correctness, nor do they establish completeness, exhaustive fault coverage, or population-level generalization.

C. External Validity

Although the benchmark evaluation was expanded in R6 to include an external held-out corpus of $N = 938$ real-world advisories from the GitHub Advisory Database, external validity remains bounded. The 938 advisories represent open-source software vulnerabilities and do not capture proprietary operational technology (OT), industrial control systems (ICS), or complex enterprise cloud service meshes. In addition, 599 advisories were rejected fail-closed due to absent environmental evidence, demonstrating that without active telemetry integration, operational applicability is constrained. Consequently, our findings demonstrate architectural feasibility, deterministic verification, and fail-closed safety rather than universal operational effectiveness across arbitrary enterprise infrastructures.

D. Conclusion Validity

The evaluation is descriptive and does not perform hypothesis testing. It does not compare remediation time, exploit outcomes, analyst workload, or prediction accuracy against a control group. The reported percentages describe the current artifact package only.

IX. Reproducibility and Lineage

The complete research package is reproducible from source artifacts. The repository tracks the complete, unbroken cryptographic commit lineage of the R6 campaign:

- Base R5 freeze: `cc4418e062101f5259c15e51dc9a1bc2A[illegible]`
- R6 pre-registration: `090ad8b727e674aac8e95864fe7[illegible]`
- Schema v2 implementation: `43664e58b4f7852d0a03c6b21ab043dec2529be9`;
- R6.1 taxonomy: `bfaece26f9f718672be6b754ad83497ac7f1`
- T2R execution freeze: `aa215569bddb2e1b341a62317cf3206d0d465a21`;
- T3 replay and T4 freeze: `c77599be1ceac1cd39d9e552eb51196cbe427f5e`;
- T4R pre-registration: `887201c13d8d646c07a0c1023795bca36`
- T4R results freeze: `00b04c86ec55eb1bca56a73841a1564f9b`
- T5 original freeze: `9da6c5e5339df5e55259f93318f7736630`
- T5-R results freeze: `2346859b319eac9146273b215eca796147`
- T6 and corpus lock: `12bf6c456054656a1bbc198d7e3729d2675098b2`;
- Differential R1 pre-result clarification: `096e2777e5f938ce70ef6a49c73847da7809415d`;
- Differential R2 pre-registration: `1bbd1b6b29abd25d5e7dc5b677fee3dae28ec6cb`;
- Differential R2 results freeze: `32407259b9e8b07f84316c5057bf885ec29e8e8f`;
- T7 held-out pre-registration: `978694618574a8962e5dc8b6c0111bc792110685`;
- T7 held-out results freeze: `a1053b4240fad485b5dc55f7e16f0f5326e94285`.

Cryptographic digests of key result artifacts are frozen in registry manifests: Held-out corpus manifest SHA-256 is `b09a8cc4...`, Differential R2 results SHA-256 is `e54d5841...`, and T7 results SHA-256 is `6d9ffb49...`. Reproduction requires executing the test suites and LaTeX compilation sequence. All recommendations require human review (`human_adjudication_completed = false`), G10B/C1/C2 datasets remain sealed under fail-closed gates, and historical access to the held-out corpus post-T7 is explicitly recorded (`held_out_accessed = true`).

A pre-registered blinded adjudication protocol is specified in Appendix A. It remains unexecuted under the G10B authorization gate, and no expert-agreement, inter-rater-reliability, or human semantic-validation results are claimed in this study.

X. Operational Adoption Path

A staged adoption process can reduce risk. In the first stage, the watcher runs in observation mode and produces recommendations that do not affect remediation queues. Analysts compare the evidence package with their normal assessment. In the second stage, accepted recommendations may pre-populate tickets while analysts remain responsible for approval. In the third stage, organizations can measure review time, disagreement rates, stale-evidence frequency, and decision consistency.

Expert evaluation should use multiple reviewers and a blinded scenario set. Agreement can be measured per Environmental metric and per final operational category. Review effort should be recorded independently of agreement so that automation does not appear beneficial merely because it encourages rapid acceptance.

A production study should also monitor reversals. When new threat or asset evidence arrives, the workflow should

generate a new trace version rather than overwrite the previous assessment. This would allow researchers to examine whether recommendations change for defensible reasons and whether uncertainty flags predict later revisions.

XI. Conclusion

This paper has presented a deterministic, machine-checkable evidence normalization, governance, and traceability workflow for operationalizing CVSS v4.0 Environmental metrics. The architecture strictly isolates official Base information from consumer deployment context, evaluates candidate metrics under explicit governance policies, enforces human authorization checkpoints, and exports structured, machine-checkable trace artifacts.

The investigation demonstrated 100% arithmetic conformance across 486,472 FIRST reference vectors and zero violations over 10,000 metamorphic executions. In differential validation against secondary implementation `cvss4py`, the workflow achieved 454,047/461,444 exact numeric concordance (98.3970%) on calculable vectors and 25,028/25,028 syntax rejection concordance (100.0%) on malformed vectors. Formulating closed-world Schema v2 eliminated subobject injection vulnerabilities (16/16 rejections in replay), while a downstream governance override contract achieved 8/8 invariant passes without modifying Equation 8 nominal formulas. In external held-out transfer across $N = 938$ real-world advisories, the workflow classified 339 cases as nominal-calculable and executed 599 fail-closed rejections under missing evidence, with zero data invention, zero autonomous overrides, and 938/938 traces validated across 3,232 diagnostic checks.

Strict claim boundaries remain: independent expert adjudication has not been completed (`human_adjudication_completed = false`), and confirmatory benchmark sets C1 and C2 remain sealed under gatekeeper protocol G10B. Future work will execute blinded expert adjudication, measure inter-rater reliability, and evaluate live telemetry integrations in production environments.

Appendix A
Pre-Registered Adjudication Protocol Specification

To support transparent external verification and future organizational deployment, this paper formalizes an open, standardized adjudication protocol specification and reproducible evaluation package (`article/expert_review/`). Crucially, this protocol is presented as a specification deliverable; no independent human expert adjudication has been concluded in the present study. Specifying this protocol does not constitute completed empirical validation and does not eliminate the construction and endogenous selection bias inherent in the 30 curated scenarios. External execution remains necessary to measure empirical inter-rater agreement and operational generalizability.

A. Blinded Review Design

Each reviewer receives a counterbalanced packet containing the Base vector, Base score, Base severity, consumer deployment context, security requirements, controls, and evidence. CVE identifiers, source URLs, watcher recommendations, priority deltas, and rationales are withheld during the independent review.

Two deterministic packet orders reduce the likelihood that fatigue or learning effects are confounded with a single presentation sequence. Reviewers record Security Requirements, Modified Base metrics, an Environmental vector, operational priority, confidence, evidence sufficiency, missing evidence, ambiguity, and review duration.

B. Agreement Measures

The analysis plan reports raw metric-level agreement in addition to chance-corrected measures. Fleiss' kappa or Krippendorff's alpha can be used for multi-reviewer categorical agreement, depending on missing responses. Ordered priority categories can be analyzed using weighted agreement. Review time, confidence, evidence sufficiency, defer rates, and watcher override rates are reported separately.

The operational priority remains a prototype category and is not an official CVSS score. Agreement with the watcher is not treated as proof that either the watcher or a reviewer is correct.

C. Adjudication

After independent responses are locked, disagreements are reviewed in a structured adjudication stage. The adjudication record distinguishes insufficient evidence, ambiguity, reviewer interpretation differences, data-entry errors, watcher errors, specification interpretation issues, and operational-priority framework issues.

This standardized protocol specification strengthens the human-in-the-loop design by defining formal procedures to measure where automation assists analysts and where it requires correction. No expert agreement results or human adjudication data are claimed in the present study.

References

[1] FIRST, "Common Vulnerability Scoring System Version 4.0," https://www.first.org/cvss/v4.0/, accessed: 2026-07-13.

[2] ——, "CVSS v4.0 Specification Document," https://www.first.org/cvss/v4.0/specification-document, accessed: 2026-07-13.

[3] ——, "CVSS v4.0 User Guide," https://www.first.org/cvss/v4.0/user-guide, accessed: 2026-07-13.

[4] ——, "CVSS v4.0 Implementation Guide," https://www.first.org/cvss/v4.0/implementation-guide, accessed: 2026-07-13.

[5] C. Frühwirth and T. Männistö, "Improving CVSS-based vulnerability prioritization and response with context information," in *2009 3rd International Symposium on Empirical Software Engineering and Measurement*, 2009, pp. 535–544.

[6] B. Jung, Y. Li, and T. Bechor, "CAVP: A context-aware vulnerability prioritization model," *Computers & Security*, vol. 116, p. 102639, 2022.

[7] H. Howland, "CVSS: Ubiquitous and broken," *Digital Threats: Research and Practice*, vol. 4, no. 1, pp. 1–12, 2023.

[8] J. Spring, A. D. Householder, E. Hatleback, A. Manion, M. Oliver, V. S. Sarvepalli, L. Tyzenhaus, and C. G. Yarbrough, "Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization, version 2.0," Carnegie Mellon University Software Engineering Institute, Tech. Rep., April 2021. [Online]. Available: https://www.sei.cmu.edu/documents/606/2021_019_001_653461.pdf

[9] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," *Journal of Cybersecurity*, vol. 6, no. 1, p. tyaa015, 2020.

[10] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system," *Digital Threats: Research and Practice*, vol. 2, no. 3, pp. 1–17, 2021.

[11] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," in *2023 IEEE European Symposium on Security and Privacy Workshops*, 2023, pp. 194–206.

[12] M. Souppaya and K. Scarfone, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-40 Rev. 4, 2022.

[13] V. Koscinski, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," in *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security*, 2025, pp. 1904–1918.

[14] B. Edwards, "cvss4py: Python implementation of CVSS v4.0 calculator," https://github.com/bjedwards/cvss4py, commit 9fe705cdb7d4a222770e0561f046d3e3f061088a, 2024.

[15] GitHub, "GitHub Advisory Database," https://github.com/github/advisory-database, accessed: 2026-10-21.

[16] National Vulnerability Database, "CVE-2026-4251 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4251, 2026, accessed: 2026-07-13.

[17] ——, "CVE-2026-4252 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4252, 2026, accessed: 2026-07-13.

[18] ——, "CVE-2026-4270 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4270, 2026, accessed: 2026-07-13.

[19] ——, "CVE-2026-28490 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-28490, 2026, accessed: 2026-07-13.

[20] ——, "CVE-2026-28498 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-28498, 2026, accessed: 2026-07-13.

[21] ——, "CVE-2026-29510 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29510, 2026, accessed: 2026-07-13.

[22] ——, "CVE-2026-29513 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29513, 2026, accessed: 2026-07-13.

[23] ——, "CVE-2026-29520 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29520, 2026, accessed: 2026-07-13.

[24] ——, "CVE-2026-29521 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-29521, 2026, accessed: 2026-07-13.

[25] ——, "CVE-2026-3644 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-3644, 2026, accessed: 2026-07-13.

[26] ——, "CVE-2026-4224 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4224, 2026, accessed: 2026-07-13.

[27] ——, "CVE-2026-4253 Detail," https://nvd.nist.gov/vuln/detail/CVE-2026-4253, 2026, accessed: 2026-07-13.